

Related Paper Review 2

SoK: Attack and Defense Landscape of Agentic AI Systems

Project	A.R.T.E.M.I.S (F26-008), FAST NUCES Lahore
Team	Hashir Rauf (23L-2572), Hira Khalid (23L-2594), Syeda Doureesha Batool (23L-2651)
Supervisor	Mr. Mubasher Hussain

1 Citation and Publication Status

J. Kim, W. Guo, and D. Song, “SoK: Attack and Defense Landscape of Agentic AI Systems,” in *Proceedings of the 35th USENIX Security Symposium (USENIX Security 2026)*, USENIX Association, 2026.

This paper is peer reviewed and accepted to USENIX Security, one of the four top-tier venues in computer security. It appears in the Cycle 1 accepted list for the 2026 symposium. It is a published conference paper, not a preprint.

2 What the Paper Does

The paper is a systematisation of knowledge, meaning it does not propose a new system but organises an entire research area into a single structured account. The authors survey 128 papers and extract 51 distinct attacks and 60 distinct defences against AI agents, which are systems that combine a language model with external tools that act on the world.

Its central argument is that an agent’s attack surface is determined by seven design dimensions. How the agent is given tools, how it stores memory, how it retrieves external content, and how much autonomy it holds each enlarge or shrink the set of attacks available against it. Security is therefore a consequence of architecture, not a feature added afterwards.

The paper examines privilege separation as a defensive pattern, drawing an analogy to the separation an operating system maintains between a trusted kernel and untrusted user programs, and applies it to isolating an agent’s planning component from untrusted external data.

3 Results and Findings

- Prompt injection is identified as the central unsolved threat. Instructions embedded in a document, a web page or a tool result can be treated by the agent as though they came from the user.
- Defences that rely on detecting malicious input are found to be unreliable, because an attacker can rephrase until detection fails. Architectural confinement is assessed as more dependable than detection.
- Human-in-the-loop approval, the defence most systems rely on, is found to have two documented failure modes. Frequent approval prompts produce decision fatigue, so users begin approving without reading. Separately, many users lack the expertise to judge what they are approving.

- The authors state plainly that approval fatigue is an open problem for the field, and offer no solution to it.
- Most surveyed defences are designed for developers or organisations with dedicated security staff, rather than for an individual running an assistant on a personal machine.

4 Strengths

The breadth is the primary strength. By covering 128 papers the authors produce a map of the field rather than a position within it, which makes the work usable as a design checklist rather than only as an argument.

The second strength is the insistence that design dimensions determine the attack surface. This reframes agent security as an architectural question, which is directly actionable when designing a system rather than when auditing one.

The third strength is the paper’s honesty about human-in-the-loop approval. Rather than presenting approval as a solved safeguard, the authors document the conditions under which it fails. This is uncomfortable but valuable for any project that depends on it.

5 Weaknesses and Limitations

As a systematisation the paper proposes no new mechanism and validates none of the surveyed defences experimentally, so the relative effectiveness of the 60 defences remains unquantified.

Its orientation is toward developers and organisations. The threat model assumes a reader able to implement privilege separation and configure sandboxes, which does not describe an ordinary desktop user.

Most significantly for our purposes, having identified approval fatigue as a documented failure of the human-in-the-loop model, the paper leaves it open. It names the problem that any approval-based system inherits without offering a remedy.

6 Relationship to A.R.T.E.M.I.S

This paper is the closest published work to the security argument our project makes, and it cuts in two directions.

It supports our central design. The finding that confinement is more dependable than detection is precisely the position our architecture takes. Our system resolves every path through a single component that canonicalises before testing containment, so a file outside a granted folder is not refused but unreachable. Our policy engine reads the proposed action and never the model’s reasoning text, which is the out-of-band evaluation the paper recommends. We also provide no code path to a destructive operation, so deletion is unavailable rather than guarded.

It also identifies a limitation we inherit and cannot claim to have solved. Our system depends on the user approving consequential actions, and the paper documents that such approval degrades with repetition. We do not solve approval fatigue. Our design reduces exposure to it by classifying actions into risk tiers, so that routine reads never prompt at all and only genuinely consequential actions interrupt the user, and by allowing a user to record a scoped decision for a repeated low-risk operation. These measures reduce

prompt frequency but do not eliminate the underlying effect. We have therefore written approval fatigue into our evaluation plan as something to be measured over repeated sessions rather than asserted away, which is the response the paper's authors call for.